

La nube y quién responde por ella

Modelos de servicio, responsabilidad compartida y el pilar de seguridad de Azure.

Rubén Schnettler • Docente

INACAP Valparaíso • Ingeniería en Informática

Unidad 2 • Bloque 1 de 3

UNIDAD 2 • SEGURIDAD EN CLOUD COMPUTING

Contenido del bloque

01 Qué es la nube

Cinco características, tres modelos de servicio y cuatro de despliegue, según NIST.

02 Quién responde por qué

El modelo de responsabilidad compartida y lo que nunca se transfiere al proveedor.

03 El pilar de seguridad de Azure

Principios de diseño y la lista de revisión SE:01 a SE:12 del Well-Architected Framework.

04 Laboratorio

La suscripción y la **primera configuración segura** del entorno de su caso.

BLOQUE

01

Qué es la nube

Antes de protegerla corresponde definir
qué la distingue de un servidor arrendado.

01 / 03 • NIST SP 800-145

Cinco características esenciales



Autoservicio bajo demanda

El cliente obtiene capacidad sin intervención humana del proveedor.



Acceso amplio por red

Los recursos se alcanzan por la red, desde distintos dispositivos.



Agrupación de recursos

La misma infraestructura atiende a muchos clientes a la vez.



Elasticidad rápida

La capacidad crece y se reduce según la demanda.



Servicio medido

El uso se mide, se controla y se cobra.

CONSECUENCIA PARA LA SEGURIDAD

El autoservicio permite que un error de configuración quede publicado en segundos, y la agrupación de recursos obliga a aislar a cada cliente de los demás.

🔗 Mell, P. y Grance, T. (2011). *The NIST definition of cloud computing* (SP 800-145). NIST. <https://doi.org/10.6028/NIST.SP.800-145>

01 / 03 • MODELOS DE SERVICIO

Tres modelos, según cuánto administra el cliente



IaaS

Infraestructura como servicio

El cliente administra el **sistema operativo**, las aplicaciones y los datos.

Azure: máquinas virtuales, discos y redes virtuales.



PaaS

Plataforma como servicio

El cliente despliega su aplicación **sin administrar servidores**.

Azure: App Service, Azure SQL Database y Storage.



SaaS

Software como servicio

El cliente **usa una aplicación terminada** y configura su uso.

Microsoft 365 y Dynamics 365.

Mientras más administra el proveedor, menos controles quedan en manos del cliente. Pero los controles sobre **datos e identidades** nunca desaparecen.

01 / 03 • MODELOS DE DESPLIEGUE

Dónde está la infraestructura y quién la comparte



Pública

Infraestructura del proveedor, disponible para cualquier cliente.



Privada

De uso exclusivo de una organización, propia o administrada por un tercero.



Comunitaria

Compartida por organizaciones con requisitos comunes.



Híbrida

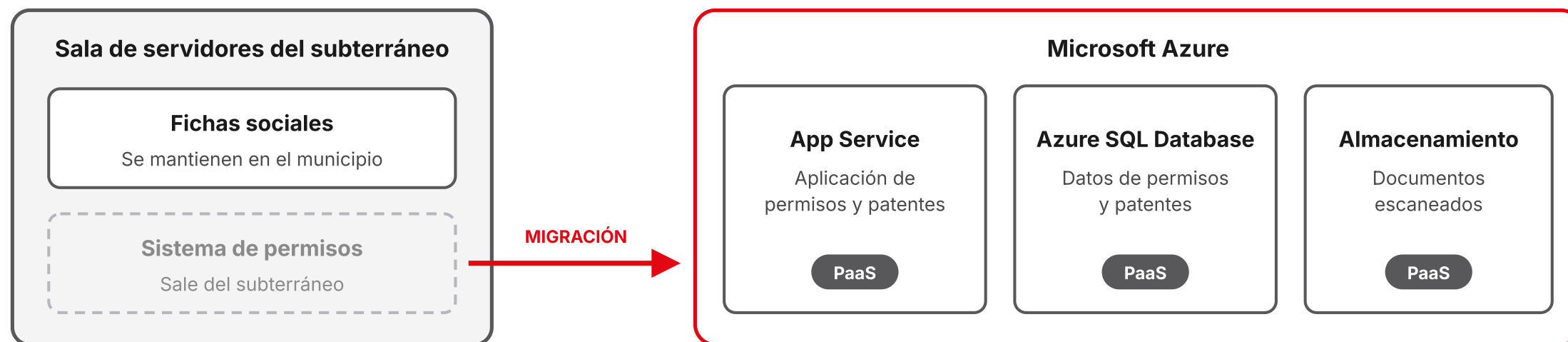
Dos o más modelos conectados, entre los que se mueven datos y aplicaciones.

EN LA PRÁCTICA

Una migración gradual produce, durante un tiempo, un modelo **híbrido**: parte de los sistemas en la nube y parte en la sala de servidores. Ambas mitades deben protegerse.

EJEMPLO • LA MUNICIPALIDAD

El sistema de permisos se traslada a Azure



LO QUE DEJA DE PREOCUPAR

Parchar el sistema operativo del servidor y la inundación del subterráneo.

LO QUE SIGUE SIENDO MUNICIPAL

Quién entra, con qué permisos, qué se publica y qué queda registrado.

BLOQUE

02

Quién responde por qué

El proveedor protege la infraestructura. La configuración, las identidades y los datos siguen siendo del cliente.

02 / 03 · MODELO DE RESPONSABILIDAD COMPARTIDA

La responsabilidad cambia con el modelo de servicio

	LOCAL	IaaS	PaaS	SaaS
Datos del cliente	Cliente	Cliente	Cliente	Cliente
Configuraciones	Cliente	Cliente	Cliente	Cliente
Identidades y usuarios	Cliente	Cliente	Cliente	Cliente
Dispositivos cliente	Cliente	Cliente	Cliente	Compartida
Aplicaciones	Cliente	Cliente	Compartida	Compartida
Controles de red	Cliente	Cliente	Compartida	Microsoft
Sistema operativo	Cliente	Cliente	Microsoft	Microsoft
Hosts físicos	Cliente	Microsoft	Microsoft	Microsoft
Red física	Cliente	Microsoft	Microsoft	Microsoft
Centro de datos físico	Cliente	Microsoft	Microsoft	Microsoft

Microsoft. (2026). *Shared responsibility in the cloud*. Microsoft Learn.
<https://learn.microsoft.com/azure/security/fundamentals/shared-responsibility> · El recuadro rojo marca lo que es del cliente en todos los modelos.

02 / 03 • IDEA CENTRAL

Lo que nunca se transfiere al proveedor

Datos

Clasificación, protección y decisión de cifrado.

Configuraciones

Cada opción que se activa o que se deja por defecto.

Cuentas

Crear, administrar y retirar el acceso de cada usuario.

Accesos

Roles, MFA (autenticación multifactor) y políticas de acceso.

ADVERTENCIA

«Está en Azure» no significa «Azure lo protege». En los dos casos que siguen, **el proveedor no fue vulnerado**: falló lo que correspondía al cliente.

CASO • UNA CONFIGURACIÓN

La plataforma de transmisión que expuso su código fuente



OCTUBRE DE 2021 • TWITCH

Un cambio de configuración en un servidor

Un tercero no autorizado accedió a documentos del **repositorio de código fuente** y a una parte de los **datos de pagos a creadores**. La empresa atribuyó el incidente a un cambio en la configuración de un servidor. Las contraseñas no quedaron expuestas y, como precaución, Twitch restableció todas las claves de transmisión.

LO QUE FALLÓ

Una **configuración**: responsabilidad del cliente en cualquier modelo de servicio.

LO QUE SE APRENDE

Cada cambio de configuración es un evento de seguridad: se revisa antes y se registra después.

🔗 Twitch. (2021, 15 de octubre). *Updates on the Twitch security incident*. <https://blog.twitch.tv/en/2021/10/15/updates-on-the-twitch-security-incident/>

CASO • MIGRAR SIN EVALUAR

Una multa por lo que no se analizó antes de migrar



JULIO DE 2019 • CAPITAL ONE

Datos de 106 millones de personas, alojados en una nube pública

Un atacante obtuvo datos de cerca de **100 millones de personas en Estados Unidos** y 6 millones en Canadá, almacenados en Amazon Web Services. En 2020 el regulador bancario sancionó al banco con **80 millones de dólares** por no establecer procesos eficaces de evaluación de riesgos antes de trasladar operaciones significativas a la nube pública.

LO QUE SE SANCIONÓ

No el ataque en sí, sino la **ausencia de evaluación de riesgos** antes de migrar.

RELACIÓN CON LA UNIDAD 1

Es exactamente el análisis del informe anterior: identificar activos, amenazas y riesgos **antes** de decidir.

🔗 Office of the Comptroller of the Currency. (2020, 6 de agosto). *OCC assesses \$80 million civil money penalty against Capital One*. [https://www.occ.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html](https://www OCC.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html)

TRABAJO COLABORATIVO

15 min • grupos de 3

Asignar la responsabilidad en el ejemplo

La municipalidad usa App Service y Azure SQL Database, ambos PaaS. Determinar quién responde: la municipalidad, Microsoft o ambos.

SITUACIÓN	RESPONDE	FUNDAMENTO
Falla eléctrica en el centro de datos de Azure		
El sistema operativo que ejecuta App Service queda sin parche		
Un funcionario inicia sesión con una contraseña débil y sin MFA		
El contenedor de documentos escaneados queda con acceso público		
La regla de red de la base admite conexiones desde cualquier dirección		

SOLUCIÓN DEL EJERCICIO

 VA AL INFORME · PASO 1

Ejemplo resuelto: quién responde

SITUACIÓN	RESPONDE	FUNDAMENTO
Falla eléctrica en el centro de datos	Microsoft	El centro de datos físico se transfiere en todos los modelos
Sistema operativo sin parche	Microsoft	En PaaS el sistema operativo lo administra el proveedor
Contraseña débil y sin MFA	Municipalidad	Las cuentas y los accesos nunca se transfieren
Contenedor con acceso público	Municipalidad	Es una configuración: siempre del cliente
Regla de red abierta a cualquier dirección	Compartida	En PaaS Microsoft da la base de red; las reglas de la aplicación las define el cliente

Solo las dos primeras filas son del proveedor. Las otras tres —**cuenta, configuración y red**— son las que se revisan en el Paso 1 de la evaluación.

BLOQUE

03

El pilar de seguridad

Microsoft publica cómo diseñar una carga de trabajo segura en Azure. Es el marco que exige la evaluación.

03 / 03 • AZURE WELL-ARCHITECTED FRAMEWORK

Cinco pilares y un modelo de confianza

El **Well-Architected Framework** (marco de buena arquitectura) evalúa una carga de trabajo en cinco pilares:

- ↻ Confiabilidad
- ✓ **Seguridad**
- 🔄 Optimización de costos
- ⚙️ Excelencia operativa
- ↗️ Eficiencia del rendimiento

Zero Trust (confianza cero) es la brújula del pilar de seguridad:

VERIFICAR EXPLÍCITAMENTE

Solo identidades de confianza realizan acciones permitidas, desde ubicaciones esperadas.

USAR ACCESO DE MÍNIMO PRIVILEGIO

La identidad correcta, con los permisos justos, por el tiempo necesario y sobre el recurso correcto.

ASUMIR LA VULNERACIÓN

Diseñar controles compensatorios que limiten el daño si una capa de defensa falla.

03 / 03 • PRINCIPIOS DE DISEÑO

Los cinco principios del pilar de seguridad

1

Planificar la preparación

Prácticas, responsables y respuesta a incidentes previstos desde el diseño.

2 • C

Proteger la confidencialidad

Accesos restringidos, datos clasificados, cifrado y auditoría.

3 • I

Proteger la integridad

Impedir modificaciones no autorizadas del diseño, la operación y los datos.

4 • A

Proteger la disponibilidad

Evitar que un incidente detenga o degrade el servicio.

5

Sostener la postura

Mejora continua: inventario, pruebas, detección y lecciones aprendidas.

Los principios 2, 3 y 4 son el **modelo CIA de la Unidad 1**, aplicado a la nube.

03 / 03 • LISTA DE REVISIÓN DEL PILAR

Doce recomendaciones, de SE:01 a SE:12

SE:01 Establecer una línea base de seguridad

SE:02 Integrar el ciclo de desarrollo seguro

SE:03 Clasificar y etiquetar los datos

SE:04 Segmentar y definir perímetros

SE:05 **Gestión de identidades y accesos estricta, condicional y auditable**

SE:06 **Aislar, filtrar y controlar el tráfico de red**

SE:07 **Cifrar los datos con métodos estándar**

SE:08 Endurecer los componentes

SE:09 **Proteger los secretos de las aplicaciones**

SE:10 **Monitoreo integral y detección de amenazas**

SE:11 Régimen integral de pruebas de seguridad

SE:12 Procedimientos de respuesta a incidentes

En rojo, las cinco que se ejercitan en esta unidad. Marco complementario: **CSA Security Guidance v5** (2024), cuyos dominios 5 y 6 tratan identidades y monitoreo de seguridad.

🔗 Microsoft. (2026). *Design review checklist for Security*. Azure Well-Architected Framework.
<https://learn.microsoft.com/azure/well-architected/security/checklist>

Qué recomendación sostiene cada paso

PASO DE LA EVALUACIÓN	CRITERIO	RECOMENDACIÓN	QUÉ SE CONFIGURA
1 · Configuración inicial	2.1.1	SE:06 · SE:07	Cifrado en tránsito y en reposo, acceso de red restringido
2 · Control de acceso	2.1.2	SE:05	MFA, roles y mínimo privilegio
3 · Identidad y permisos	2.1.3	SE:05 · SE:09	Usuarios y grupos coherentes con las funciones, sin secretos expuestos
4 · Auditoría	2.1.4	SE:10	Revisión de registros e identificación de eventos críticos
5 · Evaluación y mejora	2.1.5	SE:01	Comparación con la línea base y propuestas fundamentadas

Cada configuración del informe debe poder citar la recomendación que la justifica.

EJEMPLO RESUELTO · LA MUNICIPALIDAD

 [VA AL INFORME · PASO 1](#)

Configuración inicial segura del almacenamiento

CONFIGURACIÓN	VALOR SEGURO	WAF	NIST	QUÉ PROTEGE
Transferencia segura requerida	Activada · solo HTTPS	SE:07	SC-8	Datos en tránsito
Versión mínima de TLS	TLS 1.2	SE:07	SC-8	Protocolos obsoletos
Acceso anónimo a blobs	Deshabilitado	SE:05	AC-3	Documentos públicos por error
Cifrado en reposo	Activo, claves de Microsoft	SE:07	SC-28	Datos almacenados
Acceso de red	Solo direcciones autorizadas	SE:06	SC-7	Exposición a internet

Cada fila responde lo que pide el Paso 1: **qué se configuró, con qué valor y qué protege**. Los controles NIST provienen de SP 800-53 Rev. 5.

SE EJECUTA EN LA CONSOLA

La misma configuración, con la CLI de Azure

AZURE CLI

```
$ az login
$ az group create -n rg-permisos -l brazilsouth
$ az storage account create \
  -n stpermisosmuni01 -g rg-permisos \
  --sku Standard_LRS --https-only true \
  --min-tls-version TLS1_2 \
  --allow-blob-public-access false
$ az storage account show \
  -n stpermisosmuni01 -g rg-permisos -o tsv \
  --query "[enableHttpsTrafficOnly,
            minimumTlsVersion,
            allowBlobPublicAccess]"
True      TLS1_2      False
```

- 1 `az login` abre el navegador y, con los valores predeterminados de seguridad, exige MFA.
- 2 El **grupo de recursos** reúne todo el sistema: se protege y se elimina como una unidad.
- 3 Tres configuraciones de la tabla anterior, fijadas al crear la cuenta.
- 4 `show` con `--query` es la **evidencia** que se captura para el informe.

EL ENTORNO DE TRABAJO

Con qué se trabaja en el laboratorio



Azure for Students

- 100 USD de crédito para 12 meses
- Sin tarjeta de crédito
- Se verifica con el correo institucional
- Renovable mientras se mantenga la condición de estudiante

Microsoft Entra ID Free, el directorio de identidades incluido:

FUNCIÓN	DISPONIBLE
Usuarios y grupos	Sí
Roles de Azure, incluidos los personalizados	Sí
Valores predeterminados de seguridad, con MFA	Sí
Registros de inicio de sesión y de auditoría	Sí • 7 días
Acceso condicional	No • requiere P1

ADVERTENCIA • EL CRÉDITO ES LIMITADO

Tres reglas para trabajar sin agotar el crédito

1 Un solo grupo de recursos por caso

Todo lo que se cree durante la unidad queda dentro de él: se revisa, se audita y se elimina de una vez.

2 No crear máquinas virtuales

La evaluación se desarrolla con identidades, roles, almacenamiento y registros. Una máquina encendida consume crédito cada hora.

3 Eliminar el grupo al cerrar la evaluación sumativa

`az group delete --name rg-caso-a` • antes de eso, el entorno es la evidencia y debe conservarse.

TALLER DE LABORATORIO

60 min • con retroalimentación

[VA AL INFORME • PASO 1](#)

Levantar el entorno de su caso

1. Active la suscripción Azure for Students.
2. Cree el grupo de recursos de su caso: rg-caso-a, rg-caso-b...
3. Cree una cuenta de almacenamiento con las cinco configuraciones del ejemplo.
4. Verifique cada valor con `az storage account show` y capture la salida.
5. Registre en la bitácora tres características de seguridad y su propósito.

PRODUCTO DE LA SESIÓN

El listado del **Paso 1 de la evaluación**

formativa: características de seguridad identificadas, su propósito y la evidencia de cada una.

CRITERIO DE VERIFICACIÓN

La consulta devuelve True, TLS1_2 y False, y la captura muestra el nombre de la cuenta.

CIERRE DEL BLOQUE

Para la próxima sesión

1. Deje el entorno creado y las capturas en la bitácora.
2. Identifique los **cargos de su caso** que necesitarán acceso al entorno.
3. Revise en Microsoft Learn qué es **Microsoft Entra ID**.

BLOQUE 2 • IDENTIDAD Y ACCESO

Usuarios, grupos, MFA, roles y mínimo privilegio, aplicados sobre el entorno que se creó hoy.

REFERENCIAS

Fuentes del bloque

📖 MARCOS Y NORMAS

Cloud Security Alliance. (2024). *Security guidance for critical areas of focus in cloud computing (v5)*.

cloudsecurityalliance.org/artifacts/security-guidance-v5

Mell, P. y Grance, T. (2011). *The NIST definition of cloud computing (SP 800-145)*. NIST.

doi.org/10.6028/NIST.SP.800-145

Microsoft. (2025). *Security design principles*. Azure Well-Architected Framework. learn.microsoft.com/azure/well-architected/security/principles

Microsoft. (2026). *Shared responsibility in the cloud*.

learn.microsoft.com/azure/security/fundamentals/shared-responsibility

📖 CASOS Y RECURSOS

Office of the Comptroller of the Currency. (2020). *OCC assesses \$80 million civil money penalty against Capital One*. occ.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html

Twitch. (2021). *Updates on the Twitch security incident*. blog.twitch.tv/en/2021/10/15/updates-on-the-twitch-security-incident

Microsoft. (2026). *Microsoft Entra data retention*. learn.microsoft.com/entra/identity/monitoring-health/reference-reports-data-retention

Microsoft. (s. f.). *Azure for Students*. azure.microsoft.com/free/students

FIN DEL BLOQUE

La nube no terceriza la responsabilidad

El proveedor protege el edificio. Quién entra,
con qué permisos y qué se publica sigue siendo
decisión de la organización.

Consultas en el foro del AAI • TI3062 • Unidad 2